

Web Application Vulnerability Scan Report

■ Evil Web Reaper

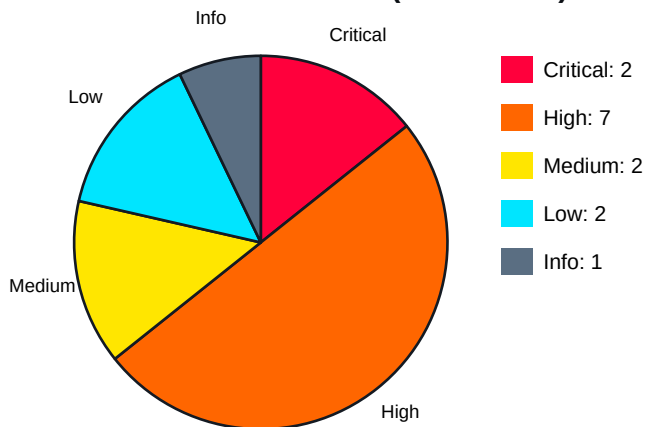
<http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#>

Scan ID	Status	Started	Duration
d9d773e19c4e4478	reporting	2026-06-30 02:24:31	—

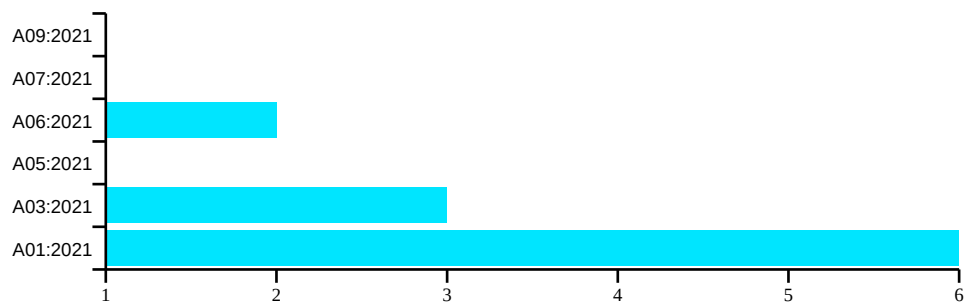
SEVERITY SUMMARY

Severity	Critical	High	Medium	Low	Info	Total
Count	2	7	2	2	1	14

SEVERITY DISTRIBUTION (PIE CHART)



OWASP TOP 10 — FINDINGS PER CATEGORY



VULNERABILITY TYPE × SEVERITY MATRIX

Category	Critical	High	Medium	Low	Info	Total
CSRF	0	6	0	0	0	6
Identification and Authentication Failures	0	1	0	0	0	1
SQL Injection	1	0	0	0	0	1

Security Logging and Monitoring Failures	0	0	0	0	1	1
Security Misconfiguration	0	0	1	0	0	1
Template Injection	1	0	0	0	0	1
Vulnerable and Outdated Components	0	0	0	2	0	2
XSS	0	0	1	0	0	1

OWASP TOP 10 (2021)

ID	Category	Findings	Highest
A01:2021	Broken Access Control	6	High
A02:2021	Cryptographic Failures	0	—
A03:2021	Injection	3	Critical
A04:2021	Insecure Design	0	—
A05:2021	Security Misconfiguration	1	Medium
A06:2021	Vulnerable and Outdated Components	2	Low
A07:2021	Identification and Authentication Failures	1	High
A08:2021	Software and Data Integrity Failures	0	—
A09:2021	Security Logging and Monitoring Failures	1	Info
A10:2021	Server-Side Request Forgery (SSRF)	0	—

DETAILED FINDINGS (14)

CRITICAL

1. SQL Injection / Error-Based

A03:2021 — Injection | CWE-89

URL: http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit# **Param:** id (GET)

Payload: ' AND EXTRACTVALUE(1,CONCAT(0x7e,USER(),0x7e))-- -

Confidence: 90%

DESCRIPTION

SQL Injection (Error-Based) confirmed in parameter 'id' on http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#. DBMS: MySQL.

EVIDENCE

DBMS: MySQL. DB Version: 10.4.32-MariaDB. Current User: root@localhost. Columns: 2

REMEDIATION

Use parameterized queries / prepared statements. Never concatenate user input into SQL strings. Apply strict input validation and least-privilege DB accounts.

CRITICAL

2. Template Injection / Server-Side Template Injection (SSTI)

A03:2021 — Injection | CWE-1336

URL: http://localhost/dvwa/vulnerabilities/sqli/?Submit=Submit&id=%3C%25%3D+7%2A7+%25%3E **Param:** id (GET)

Payload: <%= 7*7 %>

Confidence: 80%

DESCRIPTION

Parameter 'id' with '<%= 7*7 %>' evaluated to '49', indicating ERB SSTI.

EVIDENCE

```
ut type='hidden' name='user_token' value='3033b6721b79d619b749798f0f7cd045' />
```

```
</form>
```

```
<br />
```

```
<br />
```

```
<b
```

REMEDIATION

Never render user input as template; use sandboxed templating if needed.

HIGH

3. CSRF / Login

A01:2021 — Broken Access Control | CWE-352

URL: http://localhost/dvwa/vulnerabilities/csrf/

Confidence: 85%

DESCRIPTION

CSRF vulnerability (Login type) on http://localhost/dvwa/vulnerabilities/csrf/. CSRF token missing.

EVIDENCE

Form action: http://localhost/dvwa/vulnerabilities/csrf/ | Token present: False | Token fields: | Test result: None

REMEDIATION

Implement synchronizer anti-CSRF tokens on all state-changing forms. Set SameSite=Strict on session cookies. Validate Origin and Referer request headers.

HIGH

4. CSRF / GET

A01:2021 — Broken Access Control | CWE-352

URL: http://localhost/dvwa/vulnerabilities/sqli/

Confidence: 85%

DESCRIPTION

CSRF vulnerability (GET type) on http://localhost/dvwa/vulnerabilities/sqli/. CSRF token missing.

EVIDENCE

Form action: http://localhost/dvwa/vulnerabilities/sqli/ | Token present: False | Token fields: | Test result: None

REMEDIATION

Implement synchronizer anti-CSRF tokens on all state-changing forms. Set SameSite=Strict on session cookies. Validate Origin and Referer request headers.

HIGH

5. CSRF / POST

A01:2021 — Broken Access Control | CWE-352

URL: http://localhost/dvwa/vulnerabilities/weak_id/

Confidence: 85%

DESCRIPTION

CSRF vulnerability (POST type) on http://localhost/dvwa/vulnerabilities/weak_id/. CSRF token missing.

EVIDENCE

Form action: http://localhost/dvwa/vulnerabilities/weak_id/ | Token present: False | Token fields: | Test result: None

REMEDIATION

Implement synchronizer anti-CSRF tokens on all state-changing forms. Set SameSite=Strict on session cookies. Validate Origin and Referer request headers.

HIGH

6. CSRF / GET

A01:2021 — Broken Access Control | CWE-352

URL: http://localhost/dvwa/vulnerabilities/sqli/?Submit=Submit&id=1

Confidence: 85%

DESCRIPTION

CSRF vulnerability (GET type) on http://localhost/dvwa/vulnerabilities/sqli/?Submit=Submit&id=1. CSRF token missing.

EVIDENCE

Form action: http://localhost/dvwa/vulnerabilities/sqli/?Submit=Submit&id=1 | Token present: False | Token fields: | Test result: None

REMEDIATION

Implement synchronizer anti-CSRF tokens on all state-changing forms. Set SameSite=Strict on session cookies. Validate Origin and Referer request headers.

HIGH

7. CSRF / GET

A01:2021 — Broken Access Control | CWE-352

URL: http://localhost/dvwa/vulnerabilities/sqli_blind/

Confidence: 85%

DESCRIPTION

CSRF vulnerability (GET type) on http://localhost/dvwa/vulnerabilities/sqli_blind/. CSRF token missing.

EVIDENCE

Form action: http://localhost/dvwa/vulnerabilities/sqli_blind/ | Token present: False | Token fields: | Test result: None

REMEDIATION

Implement synchronizer anti-CSRF tokens on all state-changing forms. Set SameSite=Strict on session cookies. Validate Origin and Referer request headers.

HIGH

8. CSRF / Login

A01:2021 — Broken Access Control | CWE-352

URL: <http://localhost/dvwa/vulnerabilities/cryptography/>**Confidence:** 85%

DESCRIPTION

CSRF vulnerability (Login type) on <http://localhost/dvwa/vulnerabilities/cryptography/index.php>. CSRF token missing.

EVIDENCE

Form action: <http://localhost/dvwa/vulnerabilities/cryptography/index.php> | Token present: False | Token fields: | Test result: None

REMEDIATION

Implement synchronizer anti-CSRF tokens on all state-changing forms. Set SameSite=Strict on session cookies. Validate Origin and Referer request headers.

HIGH

9. Identification and Authentication Failures / Credentials Submitted via GET Request

A07:2021 — Identification and Authentication Failures | CWE-598

URL: <http://localhost/dvwa/vulnerabilities/brute/>**Confidence:** 85%

DESCRIPTION

Login form submits credentials in URL, exposing them in logs and browser history.

EVIDENCE

Login form on <http://localhost/dvwa/vulnerabilities/brute/> uses method='GET'.

REMEDIATION

Submit credentials via POST over HTTPS, no cache.

MEDIUM

10. XSS / Reflected

A03:2021 — Injection | CWE-79

URL: <http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#> **Param:** id (GET)**Payload:** `<script>alert(1)</script>`**Confidence:** 95%

DESCRIPTION

Reflected XSS in parameter 'id' on <http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#>.

EVIDENCE

Payload reflected / executed: `<script>alert(1)</script>`

REMEDIATION

Sanitize and encode all user-supplied output. Implement Content-Security-Policy headers. Use modern frameworks that auto-escape output.

MEDIUM**11. Security Misconfiguration / Directory Listing Enabled**

A05:2021 — Security Misconfiguration | CWE-548

URL: http://localhost/img/**Confidence:** 85%

DESCRIPTION

http://localhost/img/ returns directory listing, exposing file names.

EVIDENCE

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
<head>
<title>Index of /img</title>
</head>
<body>
<h1>Index of /img</h1>
<table>
<tr><th valign="top"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th></tr>
```

REMEDIATION

Disable directory indexing (Options -Indexes, autoindex off).

LOW**12. Vulnerable and Outdated Components / Server Software Version Disclosed**

A06:2021 — Vulnerable and Outdated Components | CWE-200

URL: http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#**Confidence:** 80%

DESCRIPTION

Header 'Server' reveals software version, aiding fingerprinting.

EVIDENCE

Server: Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12

REMEDIATION

Remove version headers and generator meta tags.

LOW**13. Vulnerable and Outdated Components / Server Software Version Disclosed**

A06:2021 — Vulnerable and Outdated Components | CWE-200

URL: http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#**Confidence:** 80%

DESCRIPTION

Header 'X-Powered-By' reveals software version, aiding fingerprinting.

EVIDENCE

X-Powered-By: PHP/8.2.12

REMEDIATION

Remove version headers and generator meta tags.

14. Security Logging and Monitoring Failures / No Request-Correlation Headers Observed

A09:2021 — Security Logging and Monitoring Failures | CWE-778

URL: <http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#>

Confidence: 30%

DESCRIPTION

No request correlation header observed; confirm internally that logging can trace requests.

EVIDENCE

Response headers include none of: x-request-id, x-correlation-id, x-trace-id, x-amzn-trace-id, traceparent

REMEDIATION

Add X-Request-Id or similar header to correlate requests with logs.

Generated 2026-06-30 02:25:46 UTC — For authorised security testing only.